# BÁO CÁO TIẾN ĐỘ ĐỒ ÁN TỐT NGHIỆP

## Đánh giá khả năng áp dụng CVE đối với hệ thống web bằng cách kết hợp nhiều nguồn bằng chứng

Ngày báo cáo: 19/10/2026

---

## 1 Mục tiêu và hướng thực hiện

Sau khi đề cương được giảng viên hướng dẫn thông qua, em tập trung xây dựng và đánh giá phương pháp xác định một CVE có áp dụng cho một triển khai web cụ thể hay không. Câu hỏi cần giải quyết là: **kết hợp dữ liệu về lỗ hổng với bằng chứng quan sát được từ hệ thống có giúp đánh giá đúng hơn so với chỉ đối chiếu sản phẩm và phiên bản hay không?**

Phiên bản nằm trong dải bị ảnh hưởng chưa đủ để xác nhận một triển khai thỏa mãn các điều kiện tiên quyết (preconditions) của CVE. Phương pháp trả về `Applicable`, `Not Applicable` hoặc `Unknown`, kèm bằng chứng hỗ trợ. Kết luận `Applicable` dừng ở việc xác định triển khai thỏa mãn các điều kiện liên quan; tái hiện tác động trong phòng thí nghiệm phục vụ xác lập nhãn chuẩn (ground truth).

## 2 Công việc đã hoàn thành

### 2.1 Xây dựng phương pháp và quy trình đánh giá

Em đã thiết kế và hiện thực **Fusion**, kết hợp bốn kênh thông tin: **CPE, NVD, advisory và HTTP**. Dữ liệu công khai mô tả dải phiên bản bị ảnh hưởng và điều kiện tiên quyết; phản hồi HTTP cung cấp bằng chứng về triển khai đang được đánh giá.

Fusion dùng luật ưu tiên nguồn theo phạm vi sản phẩm, nhánh phiên bản và bản phần mềm cụ thể; không xem thông tin trùng giữa các nguồn là nhiều bằng chứng độc lập. `Applicable` cần bản phần mềm bị ảnh hưởng và đủ điều kiện của ít nhất một đường gây tác động. `Not Applicable` cần căn cứ về bản phần mềm không bị ảnh hưởng hoặc đã vá, hoặc xác nhận mọi đường gây tác động liên quan đều thiếu điều kiện bắt buộc. Thiếu bằng chứng được giữ là `Unknown`.

Bốn phương pháp đối chiếu (baseline) gồm **CPE-only, NVD-only, Advisory-only và HTTP version-string-only** đã được cài đặt cùng chương trình đánh giá chung với Fusion. Các phương pháp đối chiếu dùng chung thông tin nhận diện từ HTTP nhưng khác dữ liệu và luật được phép sử dụng; chúng không phải bốn công cụ quét độc lập. Bộ kiểm thử tổng hợp hiện có **193/193 kiểm tra đạt**; kết quả này kiểm tra

việc hiện thực luật và tính chỉ số, chưa thay thế đánh giá thực nghiệm. [2, 4]

Phương pháp đã được hiện thực thành chương trình tự động. Hiện trạng triển khai như sau:

**Chức năng đã làm:**

- Năm phương pháp đánh giá (CPE-only, NVD-only, Advisory-only, HTTP version-string-only và Fusion) dưới dạng mã nguồn, dùng chung một chương trình đánh giá.
- Công cụ chạy đánh giá và tính chỉ số tự động (precision, recall, F1, coverage, Unknown rate), xuất bảng kết quả cho cả năm phương pháp.
- Bộ sinh dữ liệu đầu vào từ bảng tín hiệu, dữ liệu công khai và bản ghi HTTP đã thu thập.
- Kiểm tra toàn vẹn đầu vào bằng mã băm và các bước kiểm tra trước khi chạy, giúp kết quả tái lập được và tránh chạy nhầm dữ liệu cũ.
- Bộ kiểm thử tổng hợp 193/193 kiểm tra việc hiện thực luật và công thức chỉ số.

**Nhược điểm hiện tại:**

- Chưa tự gửi yêu cầu HTTP: đánh giá chạy trên bản ghi HTTP thu thập trước, chưa phải công cụ quét trực tiếp.
- Thu bản ghi HTTP và điền bảng tín hiệu còn làm thủ công, mỗi CVE một lần.
- Nhiều trường hợp trả Unknown (recall và coverage thấp) do điều kiện không quan sát được qua HTTP.
- Chưa có giao diện người dùng, vận hành qua dòng lệnh.

**Cải thiện dự kiến:**

- Bổ sung bộ thu thập tự gửi yêu cầu HTTP theo bảng tín hiệu để công cụ hoạt động trực tiếp trên mục tiêu.
- Bổ sung và kiểm chứng tín hiệu cho các trường hợp còn Unknown.
- Tách dữ liệu dùng để phát triển khỏi tập đánh giá.
- Đóng gói vận hành đơn giản hơn và đưa mã nguồn lên kho lưu trữ.

### 2.2 Xây dựng bộ dữ liệu và nhãn chuẩn

Bộ dữ liệu hiện gồm **32 mã CVE khác nhau**, thuộc WordPress và plugin, Drupal, Roundcube, Joomla, cùng một số trường hợp Apache/nginx. Mỗi trường hợp đánh giá gắn với một CVE, sản phẩm, phiên bản và cấu hình; một CVE có thể có nhiều trường hợp đối chứng. **Phụ lục A** liệt kê đầy đủ các CVE, mô tả ngắn cơ chế lỗi và kết quả kiểm chứng trong dự án.

Đã xác lập nhãn chuẩn cho **30 CVE**; hai CVE XSS còn chờ xác nhận thực thi mã trên trình duyệt. Tổng cộng có **69 trường hợp**: 31 `Applicable`,

36 `Not Applicable` và 2 chưa xác lập được nhãn (`Unresolved`). Nhãn chuẩn dựa trên hồ sơ phiên bản, cấu hình, bản vá và bằng chứng kiểm chứng trong phòng thí nghiệm; việc xác minh bản đã vá được ghi riêng với tái hiện thành công tác động của lỗi. Hai trường hợp `Unresolved` được báo riêng, nên tập tính chỉ số gồm **67 trường hợp**. [1]

Dữ liệu CVE công khai được lưu theo thời điểm (snapshot) trong hai đợt ngày 11/10 và 17/10, kèm nguồn và mã kiểm tra tính toàn vẹn. Bảng ánh xạ tín hiệu HTTP được cố định theo phiên bản trước mỗi lần đánh giá. Thông tin nội bộ như cấu hình và thông tin container dùng để xác lập nhãn chuẩn được tách khỏi đầu vào phương pháp. Quy trình gán nhãn đã được mô tả và rà soát, nhưng vẫn cần hoàn thiện và xin góp ý. [2]

## 3 Kết quả thực nghiệm hiện tại

### 3.1 So sánh trên bộ dữ liệu hiện tại

Bảng dưới là kết quả V3 trên **67 trường hợp có nhãn**. Mỗi trường hợp có nhãn được xếp vào một nhóm trong bảng nhầm lẫn, gồm TP, FP, TN, FN và Unknown; các chỉ số trong bảng được định nghĩa như sau:

- **TP (dương tính đúng):** ca `Applicable` được dự đoán đúng `Applicable`.
- **FP (dương tính giả):** ca `Not Applicable` bị dự đoán nhầm thành `Applicable`.
- **TN (âm tính đúng):** ca `Not Applicable` được dự đoán đúng `Not Applicable`.
- **FN (âm tính giả):** ca `Applicable` bị dự đoán nhầm thành `Not Applicable`.
- **Unknown:** ca phương pháp từ chối kết luận, tách thành $U_A$ (ca `Applicable` bị bỏ sót) và $U_N$ (ca `Not Applicable`).
- **Precision** $= \mathrm{TP}/(\mathrm{TP}+\mathrm{FP})$: tỉ lệ báo đúng trong các ca được báo `Applicable`.
- **Recall** $= \mathrm{TP}/(\mathrm{TP}+\mathrm{FN}+U_A)$: trong các ca thực sự `Applicable`, tỉ lệ được phát hiện; ca `Applicable` trả `Unknown` bị tính là bỏ sót.
- **F1** $= 2\mathrm{TP}/(2\mathrm{TP}+\mathrm{FP}+\mathrm{FN}+U_A)$: trung bình điều hòa của Precision và Recall.
- **Coverage** $= (\mathrm{TP}+\mathrm{FP}+\mathrm{TN}+\mathrm{FN})/N$: tỉ lệ ca được đưa ra kết luận (không `Unknown`).
- **Unknown rate** $= (U_A+U_N)/N$: tỉ lệ ca từ chối kết luận, với $N = \mathrm{TP}+\mathrm{FP}+\mathrm{TN}+\mathrm{FN}+U_A+U_N$.

[3]

| Phương pháp | TP | FP | TN | Precision | Recall | F1 | Coverage | Unknown rate |
|---|---|---|---|---|---|---|---|---|
| CPE-only | 13 | 3 | 11 | 0.813 | 0.419 | 0.553 | 40.3% | 59.7% |
| NVD-only | 13 | 3 | 11 | 0.813 | 0.419 | 0.553 | 40.3% | 59.7% |
| Advisory-only | 0 | 0 | 10 | N/A | 0.000 | 0.000 | 14.9% | 85.1% |
| HTTP version-string-only | 13 | 3 | 11 | 0.813 | 0.419 | 0.553 | 40.3% | 59.7% |
| **Fusion** | **6** | **0** | **13** | **1.000** | **0.194** | **0.324** | **28.4%** | **71.6%** |

*Advisory-only có precision N/A vì chưa đưa ra kết luận Applicable nào. CPE-only, NVD-only và HTTP version-string-only cho cùng kết quả dự đoán do cùng đối chiếu phiên bản với các dải bị ảnh hưởng tương đương trên bộ dữ liệu này.*

Fusion đạt **TP = 6, TN = 13, FP = 0**; **48 trường hợp trả Unknown**. Nhóm đối chiếu phiên bản đạt TP = 13 nhưng có FP = 3. Fusion giảm FP trên tập đang xét, đồng thời có nhiều trường hợp chưa thể kết luận hơn. **Chưa có cơ sở kết luận Fusion tốt hơn tổng thể**, vì recall, F1 và coverage đều thấp hơn nhóm đối chiếu này. Precision 1.000 chỉ dựa trên sáu TP, không bảo đảm FP luôn bằng 0 ở bộ dữ liệu khác.

### 3.2 Các trường hợp làm rõ vai trò của bằng chứng

- **Cấu hình làm thay đổi kết luận:** với CVE-2024-10924, hai triển khai cùng phiên bản plugin nhưng khác trạng thái 2FA có nhãn chuẩn khác nhau. Tín hiệu HTTP đã được kiểm chứng giúp Fusion phân biệt trường hợp 2FA bật và tắt; đối chiếu phiên bản vẫn cảnh báo cả hai. [3, 4]
- **Các nguồn có thể bất đồng:** với CVE-2017-1001000, dữ liệu CPE đã lưu vẫn đánh dấu WordPress 4.7.2 bị ảnh hưởng, trong khi thông báo nhà cung cấp xác định các phiên bản liên quan là 4.7 và 4.7.1. Fusion dùng thông báo đúng phạm vi để loại FP ở bản 4.7.2. [2, 3]
- **Biết có bản vá chưa đủ để nhận diện bản đang chạy:** trường hợp nginx dùng gói Ubuntu đã vá nhưng phản hồi HTTP không cho biết số hiệu bản sửa đổi của gói. Không nối được bằng chứng HTTP với bản đã vá, cả năm phương pháp đều trả `Unknown`; trường hợp này chưa thể hiện ưu thế của Fusion. [1, 3]

### 3.3 Diễn biến qua các lần đánh giá

Ở V1, Fusion có TP = 0. Sang V2, bổ sung và kiểm chứng tín hiệu về tuyến API, 2FA và biểu mẫu đăng ký giúp TP tăng từ 0 lên 3 trên cùng tập 62 trường hợp có nhãn. V3 bổ sung năm trường hợp của Joomla và Backup Migration, đưa TP lên 6. Dự đoán trên các trường hợp cũ giữa V2 và V3 không đổi; mức tăng ở V3 phản ánh dữ liệu bổ sung, chưa phải cải tiến phương pháp trên cùng tập đánh giá. [3, 4]

## 4 Hạn chế và vấn đề còn mở

**Khả năng quan sát qua HTTP còn hạn chế.** Trong 31 trường hợp có nhãn chuẩn `Applicable`, Fusion trả `Unknown` ở 25 trường hợp. Phân tích bảng tín hiệu hiện tại cho thấy: 3 trường hợp có thể xem xét bổ sung bản ghi HTTP và kiểm chứng đầu dò (probe); 2 trường hợp cần định nghĩa thêm đầu dò; 20 trường hợp còn vướng phiên bản bị ẩn hoặc điều kiện chưa có phép quan sát phù hợp trong thiết kế hiện tại. Phân loại này chưa chứng minh các điều kiện đó không thể quan sát qua HTTP bằng mọi cách. Bổ sung bằng chứng cũng chưa bảo đảm sẽ chuyển được các trường hợp này thành dự đoán đúng. [5]

**Kết quả còn mang tính thăm dò.** Một phần dữ liệu đã dùng để xây luật hoặc kiểm chứng tín hiệu, nên không thể xem toàn bộ 67 trường hợp là tập đánh giá tách khỏi quá trình phát triển. Các cấu hình của cùng CVE có liên hệ với nhau; CVE-2023-6553 chẳng hạn đóng góp hai trường hợp `Applicable` khi plugin bật và khi tắt nhưng tệp vẫn còn. Chỉ số được tính theo trường hợp triển khai, không phải tỷ lệ trên 30 CVE độc lập. [1, 3]

**Hai trường hợp XSS vẫn Unresolved.** CVE-2023-5631 chưa xác nhận được thực thi mã do hạn chế của kỹ thuật SVG trong trình duyệt đang dùng. Với CVE-2019-6341, đã lưu được tệp ở bản bị ảnh hưởng nhưng trình duyệt nhận nội dung là `text/plain`, chưa thực thi JavaScript; các đường thử khác còn vướng lưu trữ hoặc cấu hình. Hai trường hợp tiếp tục giữ `Unresolved`; chưa gán `Applicable` chỉ từ khác biệt phía máy chủ. [1]

**Cần làm rõ phạm vi phép quan sát.** Đầu dò Joomla đọc cấu hình qua yêu cầu không cần xác thực, có thể trực tiếp quan sát tác động tiết lộ thông tin. Phạm vi “đánh giá không khai thác trực tiếp” cần được rà theo từng phép kiểm tra trước khi mô tả toàn bộ quy trình là quan sát không gây tác động. [6]

## 5 Kế hoạch cho đợt tiếp theo

1. **Hoàn thiện quy trình đánh giá:** rà quy tắc gán nhãn, phạm vi quyền quan sát và cách tách dữ liệu phát triển khỏi dữ liệu đánh giá; bổ sung thông tin nguồn để truy ngược mỗi dự đoán về bằng chứng.
2. **Bổ sung bằng chứng HTTP:** kiểm tra ba trường hợp đã có đầu dò nhưng thiếu kiểm chứng, sau đó xem xét hai trường hợp cần thêm đầu dò. Lưu cập nhật thành phiên bản mới và giữ kết quả cũ để so sánh trên cùng tập đánh giá.
3. **Tiếp tục tái hiện hai trường hợp XSS:** nếu chưa đủ bằng chứng thực thi trên trình duyệt thì tiếp tục báo `Unresolved`, không đưa vào mẫu số tính chỉ số.
4. **Hoàn thiện khảo sát và bản thảo đồ án:** viết phần bài toán, phương pháp, bộ dữ liệu và kết quả; làm rõ vai trò của VAVI, Vuln2Action và các nghiên cứu hợp nhất bằng chứng đã khảo sát. Công cụ so sánh bổ sung cần tương đồng về đầu vào, đầu ra và bài toán.

## 6 Câu hỏi và thắc mắc

1. Với kết quả giảm FP nhưng recall và coverage còn thấp, hướng phân tích sự đánh đổi giữa precision, recall và coverage, kèm bổ sung bằng chứng còn thiếu, đã phù hợp với yêu cầu đóng góp của đồ án chưa?
2. Xin góp ý về quy tắc gán nhãn và phạm vi quan sát HTTP, đặc biệt với trường hợp có đăng nhập và đầu dò trực tiếp quan sát tác động của lỗi như đọc cấu hình Joomla.
3. Với quy mô 30 CVE có nhãn chuẩn và 67 trường hợp đánh giá hiện tại, đợt tới nên ưu tiên hoàn thiện bằng chứng và tách tập đánh giá khỏi quá trình phát triển, hay mở rộng thêm số CVE?

## Hồ sơ đối chiếu trong dự án

[1] Danh mục và nhãn chuẩn: experiments/26cve/registry.md; experiments/topup-2026-10-17/cases/; experiments/methods/data/cases.json. Hai trường hợp XSS: mục 36 và 37 trong context/CURRENT_STATE.md.

[2] Luật, bảng tín hiệu và dữ liệu: notes/fusion-design-2026-10-10.md; notes/ground-truth-protocol.md; notes/collector-mapping-30cve.md; data/public-snapshot/; data/public-snapshot-2026-10-17/.

[3] Kết quả V1, V2 và V3: experiments/methods/output/, các thư mục benchmark/, benchmark-v2/, benchmark-v3/.

[4] Kiểm chứng tín hiệu: experiments/methods/NOTE-v2-captures-benchmark-2026-10-16.md. Kiểm thử: experiments/methods/fixture/output/fixture-report.json.

[5] Phân tích các trường hợp Applicable trả Unknown: notes/u_a-breakdown-2026-10-19.md.

[6] Phạm vi đầu dò: reviews/Review_mapping_topup_phanquyet_2026-10-17.md.

## Phụ lục A. Danh mục các CVE trong bộ dữ liệu

Phụ lục gồm **32 CVE: 30 đã có nhãn chuẩn và 2 Unresolved**, được nhóm theo sản phẩm. Các phiên bản dưới đây là những bản đã kiểm tra trong dự án; nhãn gắn với cấu hình và quyền truy cập của từng trường hợp. Kết quả trong phụ lục là **nhãn chuẩn**, phân biệt với dự đoán của Fusion hay các phương pháp đối chiếu. [1, 2]

Quy ước trong bảng: **A = Applicable**, **NA = Not Applicable**; **Unresolved** là chưa đủ bằng chứng để xác lập nhãn. Một CVE có thể có cả trường hợp A và NA. Các loại lỗi dùng ký hiệu thông dụng như XSS, SQLi, XXE, SSRF và RCE; các mô tả đi kèm nêu tác động và điều kiện chính.

### A.1 WordPress core (6 CVE)

| CVE | Tóm tắt cơ chế và điều kiện chính | Phiên bản và kiểm chứng trong dự án |
|---|---|---|
| **CVE-2015-3440** | Stored XSS qua bình luận quá dài: dữ liệu bị cơ sở dữ liệu cắt ngắn có thể tạo nội dung thực thi trên trình duyệt. | 4.2.0: A; 4.2.1: NA. Bản ảnh hưởng dựng từ mã nguồn, có chuỗi nhận diện 4.2-src; đã quan sát JavaScript chạy. |
| **CVE-2017-1001000** | Kiểm tra quyền chưa đúng trong REST API cho phép sửa nội dung bài viết không cần xác thực. | 4.7.1: A; 4.7.2: NA. Đã xác nhận bài viết bị sửa ở bản ảnh hưởng. |
| **CVE-2019-8942** | Chuỗi lỗi xử lý và cắt ảnh có thể dẫn tới RCE; cần tài khoản Author và điều kiện về xử lý ảnh, quyền ghi tệp. | 5.0.0: A; 5.0.1: NA. Đã tạo tệp đánh dấu trong môi trường thử nghiệm. |
| **CVE-2021-29447** | XXE khi xử lý thông tin iXML trong tệp WAV, cho phép đọc tệp và gửi dữ liệu ra ngoài; cần quyền tải tệp và PHP 8 trong ca đã dựng. | 5.7.0/PHP 8.0.3: A; 5.7.1/PHP 8.0.6: NA. Đã nhận nội dung tệp đánh dấu tại máy kiểm chứng. |

*Tiếp ở trang sau*

| CVE | Tóm tắt cơ chế và điều kiện chính | Phiên bản và kiểm chứng trong dự án |
|---|---|---|
| **CVE-2022-21661** | SQLi trong WP_Query khi đầu vào do người dùng kiểm soát được chuyển tới truy vấn; đường lỗi phụ thuộc plugin hoặc theme. | 5.8.2: A; 5.8.3: NA. Cùng dùng Ele Custom Skin 3.1.3; xác nhận bằng độ trễ và nhật ký cơ sở dữ liệu. |
| **CVE-2023-2745** | Tham số wp_lang cho phép tải tệp dịch .mo ngoài thư mục ngôn ngữ. Khả năng dẫn tới XSS còn phụ thuộc tệp dịch do kẻ tấn công kiểm soát. | 6.2.0: A; 6.2.1: NA. Đặt sẵn tệp .mo và quan sát nội dung đánh dấu; chưa tái hiện JavaScript thực thi. |

### A.2 Plugin WordPress (10 CVE)

| CVE | Tóm tắt cơ chế và điều kiện chính | Phiên bản và kiểm chứng trong dự án |
|---|---|---|
| **CVE-2019-10692** | **WP Google Maps:** SQLi qua tham số chọn trường trong REST API, cho phép truy vấn dữ liệu không cần xác thực. | 7.11.17: A; 7.11.18: NA. Đã trả được dữ liệu đánh dấu qua truy vấn. |
| **CVE-2020-25213** | **File Manager:** đầu nối elFinder công khai cho phép tải tệp PHP không cần xác thực, dẫn tới RCE. | 6.0: A; 8.0.6: NA. Dùng 8.0.6 thay đối chứng 6.9 do gói cũ không còn tải được. |
| **CVE-2021-24917** | **WPS Hide Login:** xử lý tiêu đề Referer làm lộ URL đăng nhập đã cấu hình ẩn qua phản hồi chuyển hướng. | 1.9: A; 1.9.1: NA. Đã xác nhận lộ URL; tác động này không đồng nghĩa bỏ qua xác thực. |
| **CVE-2023-28121** | **WooCommerce Payments:** tin cậy tiêu đề yêu cầu giả mạo cho phép bỏ qua xác thực và hoạt động dưới tài khoản được chỉ định. | 5.6.1: A; 5.6.2: NA. Cùng dùng WooCommerce 7.5.1; đã xác nhận tạo tài khoản quản trị. |

*Tiếp ở trang sau*

| CVE | Tóm tắt cơ chế và điều kiện chính | Phiên bản và kiểm chứng trong dự án |
|---|---|---|
| **CVE-2023-32243** | **Essential Addons for Elementor:** thiếu kiểm tra khóa đặt lại mật khẩu, cho phép đổi mật khẩu tài khoản đã biết; cần Elementor và mã nonce có thể lấy công khai. | 5.7.1: A; 5.7.2: NA. Đã xác nhận đổi mật khẩu và đăng nhập tài khoản quản trị. |
| **CVE-2023-3460** | **Ultimate Member:** bỏ qua bộ lọc metadata trong biểu mẫu đăng ký cho phép tự gán quyền quản trị. | 2.6.6: A; 2.6.7: NA. Cần đăng ký công khai; đã xác nhận tài khoản mang quyền administrator. |
| **CVE-2023-5798** | **Assistant:** SSRF qua chức năng proxy ảnh, khiến máy chủ truy cập URL do người dùng cung cấp; cần quyền Editor trở lên. | 1.4.3: A; 1.4.4: NA. Đã ghi nhận yêu cầu tới máy kiểm chứng. |
| **CVE-2023-6553** | **Backup Migration:** đầu vào điều khiển việc nạp tệp PHP có thể dẫn tới RCE không cần xác thực. Tắt plugin vẫn để lại tệp có thể truy cập trong lab. | 1.3.7 bật và tắt nhưng còn tệp: A; 1.3.8 bật: NA. Cả hai trạng thái 1.3.7 đều tạo được tệp đánh dấu. |
| **CVE-2024-10924** | **Really Simple Security:** bỏ qua xác thực trong luồng thiết lập 2FA, cho phép nhận phiên đăng nhập của người dùng mục tiêu. | 9.1.1.1 bật 2FA: A; tắt 2FA: NA; 9.1.2 bật 2FA: NA. Đã xác nhận cookie đăng nhập và truy cập quản trị. |
| **CVE-2024-28000** | **LiteSpeed Cache:** hash xác thực yếu trong chức năng mô phỏng vai trò của crawler có thể cho phép giả mạo người dùng và nâng quyền. | 6.3.0.1: A; 6.4: NA. Lab cung cấp hash từ cơ sở dữ liệu thay bước vét cạn, rồi xác nhận tạo tài khoản quản trị. |

### A.3 Drupal core (6 CVE)

| CVE | Tóm tắt cơ chế và điều kiện chính | Phiên bản và kiểm chứng trong dự án |
|---|---|---|
| **CVE-2014-3704** | SQLi trong xử lý tham số dạng mảng của Database API, cho phép tác động truy vấn trước khi đăng nhập. | 7.31: A; 7.32: NA. Đã xác nhận biểu thức SQL được thực thi. |
| **CVE-2018-7600** | Đầu vào trong Form API có thể đưa hàm xử lý nguy hiểm vào cấu trúc biểu mẫu, dẫn tới RCE không cần đăng nhập. | 8.5.0: A; 8.5.1: NA. Dùng biểu mẫu đăng ký mở; đã quan sát đầu ra đánh dấu. |
| **CVE-2018-7602** | Chuỗi xử lý tham số destination trong biểu mẫu có thể dẫn tới RCE sau đăng nhập. | 7.58: A; 7.59: NA. Lab dùng tài khoản quản trị và xác nhận tạo tệp đánh dấu; cặp đã kiểm chứng thuộc Drupal 7. |
| **CVE-2019-6340** | Giải tuần tự hóa dữ liệu không an toàn qua REST hoặc JSON:API có thể dẫn tới RCE; lab cần quyền tạo nội dung và trường dữ liệu phù hợp. | 8.6.9 bật REST hoặc JSON:API: A; tắt cả hai: NA; 8.6.10: NA. Đã xác nhận tệp đánh dấu; JSON:API dùng module bổ sung. |
| **CVE-2019-6341** | Tên tệp có UTF-8 không hợp lệ có thể làm mất phần mở rộng khi tải lên, tạo điều kiện cho stored XSS. | Đã so sánh 8.6.12/8.6.13; nhãn cuối: **Unresolved**. Có khác biệt lưu tệp nhưng chưa quan sát JavaScript chạy trên trình duyệt. |

*Tiếp ở trang sau*

| CVE | Tóm tắt cơ chế và điều kiện chính | Phiên bản và kiểm chứng trong dự án |
|---|---|---|
| **CVE-2020-13671** | Lọc tên tệp chưa đúng có thể giữ phần mở rộng nguy hiểm trong tên tệp tải lên; tác động còn phụ thuộc trường tải tệp và cấu hình máy chủ. | 8.9.8 mặc định: NA; cho phép phần mở rộng nguy hiểm: A; 8.9.9: NA. Đã kiểm chứng xử lý tên tệp; chưa tái hiện RCE hoàn chỉnh. |

### A.4 Roundcube Webmail (6 CVE)

| CVE | Tóm tắt cơ chế và điều kiện chính | Phiên bản và kiểm chứng trong dự án |
|---|---|---|
| **CVE-2020-12625** | Stored XSS do nội dung CDATA trong thư HTML không được mã hóa đúng; người nhận cần đăng nhập và mở thư. | 1.4.3: A; 1.4.4: NA. Đã quan sát JavaScript thực thi trên trình duyệt. |
| **CVE-2020-12640** | Tùy chọn plugins chứa đường dẫn không hợp lệ có thể nạp tệp cục bộ. Cần khả năng sửa cấu hình và ghi tệp PHP cục bộ. | 1.4.3 mặc định: NA; cấu hình mô phỏng installer và tệp đặt sẵn: A; 1.4.4: NA. Đã xác nhận tệp đánh dấu. |
| **CVE-2020-12641** | Chèn lệnh qua đường dẫn công cụ chuyển đổi ảnh trong cấu hình; tác động được kích hoạt khi xử lý ảnh đính kèm. | 1.4.3 mặc định: NA; cấu hình mô phỏng installer: A; 1.4.4: NA. Đã tạo tệp đánh dấu; bước kích hoạt dùng phiên hộp thư. |
| **CVE-2021-44026** | SQLi khi dữ liệu sắp xếp/tìm kiếm đi qua phiên đăng nhập tới truy vấn danh bạ; cần tài khoản và dữ liệu danh bạ. | 1.4.11: A; 1.4.12: NA. Đã xác nhận độ trễ truy vấn có kiểm soát. |

*Tiếp ở trang sau*

| CVE | Tóm tắt cơ chế và điều kiện chính | Phiên bản và kiểm chứng trong dự án |
|---|---|---|
| **CVE-2023-5631** | Bộ lọc thư HTML có thể bị vượt qua bằng biến thể dữ liệu SVG, tạo nguy cơ stored XSS. | Đã so sánh 1.4.11/1.5.5; nhãn cuối: **Unresolved**. Có khác biệt phía máy chủ nhưng trình duyệt chặn kỹ thuật SVG đang thử. |
| **CVE-2024-37383** | Lọc SVG animate chưa đúng có thể biến liên kết thành nội dung thực thi JavaScript; người dùng cần mở thư và nhấp liên kết. | 1.5.6: A; 1.5.7: NA. Đã quan sát JavaScript chạy sau thao tác nhấp trên trình duyệt. |

### A.5 Apache HTTP Server và nginx (3 CVE)

| CVE | Tóm tắt cơ chế và điều kiện chính | Phiên bản và kiểm chứng trong dự án |
|---|---|---|
| **CVE-2021-41773** | Xử lý đường dẫn chưa đúng có thể cho phép đọc tệp ngoài thư mục web khi cấu hình cấp quyền truy cập. | 2.4.49 nới quyền: A; mặc định: NA; 2.4.51: NA. Chỉ đọc tệp đánh dấu, CGI tắt; đối chứng thăm dò chưa hoàn toàn tương đương. |
| **CVE-2021-42013** | Bản sửa lỗi đường dẫn trước đó chưa đầy đủ, cho phép biến thể mã hóa kép vượt kiểm tra và đọc tệp ngoài thư mục web. | 2.4.50 nới quyền: A; 2.4.51: NA. Chỉ đọc tệp đánh dấu, CGI tắt. |
| **CVE-2021-23017** | Lỗi off-by-one trong bộ phân giải DNS có thể ghi vượt bộ nhớ khi xử lý phản hồi DNS. | Gói Ubuntu 1.18.0-6ubuntu14.21: NA do đã có bản vá backport. Chỉ xác minh bản đã vá; không tái hiện khai thác. |

*Tiếp ở trang sau*

| CVE | Tóm tắt cơ chế và điều kiện chính | Phiên bản và kiểm chứng trong dự án |
|---|---|---|

### A.6 Joomla (1 CVE)

| CVE | Tóm tắt cơ chế và điều kiện chính | Phiên bản và kiểm chứng trong dự án |
|---|---|---|
| **CVE-2023-23752** | **Joomla! CMS:** kiểm tra quyền API chưa đúng cho phép người chưa đăng nhập đọc cấu hình; dữ liệu nhạy cảm có thể bị tiết lộ. | 4.2.7: A; 4.2.8: NA. Đã xác nhận giá trị đánh dấu thực trong cấu hình bị lộ. |

Hồ sơ chi tiết gồm danh mục [1], nhãn trong experiments/methods/data/cases.json và các README theo mã CVE tại experiments/26cve/. Các trường hợp thí điểm được lưu tại experiments/pilot-3cve/ và experiments/reproduce-cve-2021-41773/; hai CVE bổ sung tại experiments/topup-2026-10-17/cases/. Những nhãn đã chấp nhận được giữ nguyên; mức kiểm chứng của từng trường hợp được ghi cụ thể trong bảng.

## Phụ lục B. Thuật ngữ

**CPE** Common Platform Enumeration — chuẩn định danh sản phẩm và phiên bản phần mềm.

**NVD** National Vulnerability Database — cơ sở dữ liệu lỗ hổng của NIST.

**advisory** Thông báo bảo mật của nhà cung cấp về lỗ hổng và bản vá.

**HTTP** Giao thức truyền tải siêu văn bản; trong đồ án chỉ bằng chứng quan sát qua phản hồi HTTP.

**Fusion** Phương pháp hợp nhất bốn nguồn bằng chứng do đồ án đề xuất.

**baseline** Phương pháp đối chiếu dùng một nguồn duy nhất.

**Applicable / Not Applicable / Unknown** Ba kết luận của phương pháp: áp dụng / không áp dụng / chưa xác định.

**TP / FP / TN / FN** Dương tính đúng / dương tính giả / âm tính đúng / âm tính giả.

**precision** Độ chính xác — tỉ lệ báo đúng trong các ca được báo Applicable.

**recall** Độ phủ — tỉ lệ phát hiện đúng trong các ca thực sự Applicable.

**F1** Trung bình điều hòa của precision và recall.

**coverage** Mức bao phủ — tỉ lệ ca được đưa ra kết luận (không Unknown).

**Unknown rate** Tỉ lệ ca phương pháp từ chối kết luận.